

Plan de Traitement des Risques — TechShop SAS

Version : 1.0
Date : Juin 2026
Auteur : Dorian Poncelet (Consultant GRC)
Validé par : Marie Laurent (DG) + Thomas Rivet (DSI) — Juin 2026
Statut : Validé
Références : ISO 27001:2022 Clause 6.1.3 / Registre des risques v1.0

Rappel de la méthode

Le plan de traitement des risques (PTR) formalise les décisions prises en Atelier 5 EBIOS RM.
Il couvre uniquement les risques dont la criticité brute est ≥ 6 (Modéré à Élevé).
Les risques à criticité ≤ 4 sont acceptés sans mesure spécifique et feront l'objet d'une surveillance annuelle.

Stratégies de traitement

Stratégie	Définition	Risques TechShop
Réduire	Mettre en place des contrôles pour baisser V et/ou I	R01, R02, R03, R05, R06, R07, R09, R10, R11, R12, R13, R14, R15
Transférer	Déléguer le risque à un tiers (assurance, sous-traitant)	R04 (Stripe)
Accepter	Assumer le risque résiduel — décision formelle de la direction	R02 résiduel
Éviter	Cesser l'activité génératrice de risque	Aucun

Mesures de traitement détaillées

MESURE M01 — Déploiement MFA généralisé Google Workspace
Risque adressé : R03 (Criticité brute 12/16 -> résiduelle cible 3/16)
Contrôle ISO : A.8.5 — Authentification sécurisée

Champ	Détail
Description	Activer l'authentification multi-facteurs (MFA) sur les 47 comptes Google Workspace. Exclure les comptes de service (utiliser des clés API à la place). Imposer Google Authenticator ou clé FIDO2.
Responsable	Thomas Rivet (DSI)
Ressources	Interne uniquement — 4h DSI. Google Workspace Admin Console.
Coût estimé	0 € (fonctionnalité incluse dans GW Business Starter)
Échéance	31 juillet 2026 — URGENT
Indicateur de suivi	% comptes GW avec MFA activé (cible : 100%) — rapport mensuel Admin Console
Criticité brute	[ELEVE] 12/16
Criticité résiduelle cible	[OK] 3/16
Preuve de clôture	Capture écran rapport Admin Console "Security > Authentication > 2-Step Verification"

MESURE M02 — Migration sauvegardes S3 vers eu-west-3 (RGPD)

Risque adressé : R07 (Criticité brute 12/16 -> résiduelle cible 2/16)

Contrôle ISO : A.5.33, A.5.34 — Protection des données / RGPD

Champ	Détail
Description	1/ Supprimer la réplication S3 vers us-east-1. 2/ Configurer la réplication uniquement vers eu-west-3 (Paris). 3/ Signer le DPA AWS (Data Processing Agreement) avec clauses SCC. 4/ Documenter dans le registre des traitements RGPD.
Responsable	Thomas Rivet (DSI) + Sophie Blanc (DPO)
Ressources	Interne : 1 journée DSI + 2h DPO. AWS Console + AWS DPA (gratuit).
Coût estimé	~50 €/mois de surcoût stockage eu-west-3 vs us-east-1 (prix légèrement supérieur)
Échéance	31 juillet 2026 — URGENT
Indicateur de suivi	Zéro bucket S3 actif en us-east-1 contenant des données personnelles
Criticité brute	[ELEVE] 12/16
Criticité résiduelle cible	[OK] 2/16
Preuve de clôture	AWS Config rule + capture écran politique de réplication S3 + DPA signé

MESURE M03 — Activation S3 Object Lock (protection anti-ransomware)

Risque adressé : R11 (Criticité brute 8/16 -> résiduelle cible 3/16), R01 (contribution)

Contrôle ISO : A.8.13 — Sauvegarde des informations

Champ	Détail
Description	1/ Activer S3 Object Lock en mode COMPLIANCE sur le bucket de sauvegardes (rétention 30 jours minimum). 2/ Créer un compte AWS secondaire dédié aux sauvegardes (isolation du compte principal). 3/ Mettre en place une politique IAM "write-only" pour le compte de production (ne peut pas supprimer les backups).
Responsable	Thomas Rivet (DSI)
Ressources	Interne : 1 journée DSI. Surcoût AWS négligeable (Object Lock gratuit).
Coût estimé	0 € (Object Lock inclus dans S3 Standard)
Échéance	31 août 2026
Indicateur de suivi	Object Lock activé + test de restauration réussi documenté
Criticité brute	[ELEVE] 8/16
Criticité résiduelle cible	[OK] 3/16
Preuve de clôture	AWS Console capture + rapport de test restauration signé DSI

MESURE M04 — Formalisation procédure offboarding (désactivation comptes)

Risque adressé : R05 (Criticité brute 9/16 -> résiduelle cible 3/16)

Contrôle ISO : A.6.5, A.5.18 — Cessation de contrat / Droits d'accès

Champ	Détail
Description	1/ Rédiger une checklist offboarding informatique (désactivation GW, Odoo, HubSpot, VPN, AWS le jour du départ). 2/ Intégrer la checklist dans le processus RH de départ. 3/ Réaliser un audit des comptes actifs actuels vs liste des employés — supprimer les comptes orphelins.
Responsable	Thomas Rivet (DSI) + DRH
Ressources	Interne : 4h DSI + 2h RH
Coût estimé	0 €
Échéance	31 août 2026
Indicateur de suivi	0 compte actif appartenant à un ex-employé (audit trimestriel)
Criticité brute	[ELEVE] 9/16
Criticité résiduelle cible	[OK] 3/16
Preuve de clôture	Checklist offboarding signée DRH + résultats audit comptes

MESURE M05 — Renforcement WAF Cloudflare (mode blocage OWASP)

Risque adressé : R02 (contribution), R06 (Criticité 9/16 -> 6/16), R14, R15

Contrôle ISO : A.8.22 — Filtrage Web / WAF

Champ	Détail
Description	1/ Passer les règles WAF Cloudflare de mode "Log" à mode "Block" pour les règles OWASP Top 10. 2/ Activer les règles spécifiques WordPress (Cloudflare Managed Ruleset). 3/ Configurer les alertes WAF vers email DSI. 4/ Revue mensuelle des règles et faux positifs.
Responsable	Thomas Rivet (DSI)
Ressources	Interne : 4h DSI. Cloudflare Pro (21€/mois — déjà abonné).
Coût estimé	0 € (inclus dans abonnement Cloudflare Pro existant)
Échéance	31 août 2026
Indicateur de suivi	Nombre d'attaques bloquées/mois (dashboard Cloudflare) + 0 bypass documenté
Criticité brute	R06 : [ELEVE] 9/16
Criticité résiduelle cible	R06 : [MODERE] 6/16
Preuve de clôture	Capture Cloudflare WAF en mode Block + rapport mensuel d'activité

MESURE M06 — Déploiement EDR sur serveurs OVH

Risque adressé : R01 (contribution majeure — Criticité brute 12/16 -> résiduelle 6/16), R10

Contrôle ISO : A.8.7 — Protection contre les maliciels

Champ	Détail
Description	1/ Déployer un agent EDR (Endpoint Detection & Response) sur les 2 serveurs VPS OVH (WooCommerce) et le serveur Odoo. 2/ Solutions évaluées : CrowdStrike Falcon Go, Wazuh (open source), ou ESET Protect. 3/ Configurer les alertes temps réel vers DSI. 4/ Politique de réponse aux incidents EDR.
Responsable	Thomas Rivet (DSI)
Ressources	Interne : 2 jours déploiement. Solution retenue : Wazuh (open source, hébergé sur VPS dédié).
Coût estimé	20 €/mois (VPS Wazuh manager) ou 0 € si intégré Grafana existant
Échéance	30 septembre 2026
Indicateur de suivi	Agents EDR actifs sur 100% des serveurs + temps de détection moyen < 5 min
Criticité brute	R01 : [ELEVE] 12/16
Criticité résiduelle cible	R01 : [MODERE] 6/16
Preuve de clôture	Dashboard Wazuh + rapport d'installation + premier test de détection

MESURE M07 — Test de restauration des sauvegardes (PRA)

Risque adressé : R01 (RTO/RPO), R08, R11

Contrôle ISO : A.8.13, A.8.14, A.5.29 — Backup / Redondance / Continuité

Champ	Détail
Description	1/ Réaliser un test de restauration complète depuis les backups S3 (WooCommerce + BDD Odoo). 2/ Mesurer et documenter le RTO réel (temps de remise en service). 3/ Mesurer le RPO réel (données perdues). 4/ Formaliser le PRA avec les résultats. 5/ Planifier les tests trimestriels suivants.
Responsable	Thomas Rivet (DSI)
Ressources	Interne : 1 journée DSI + environnement de test OVH (1 VPS temporaire ~5€)
Coût estimé	5 € (VPS test temporaire)
Échéance	30 septembre 2026
Indicateur de suivi	RTO mesuré $\leq$ 4h, RPO $\leq$ 24h — rapport de test signé trimestriel
Criticité brute	R08 : [MODERE] 6/16
Criticité résiduelle cible	R08 : [OK] 4/16
Preuve de clôture	Rapport de test restauration avec RTO/RPO mesurés, signé DSI + DG

MESURE M08 — Formation et sensibilisation sécurité (tous employés)

Risque adressé : R10 (Criticité brute 8/16 -> résiduelle 4/16)

Contrôle ISO : A.6.3 — Sensibilisation et formation — **GAP CRITIQUE SoA**

Champ	Détail
Description	1/ Former les 47 employés à la sécurité informatique de base (phishing, mots de passe, signalement incidents). 2/ Réaliser une simulation de phishing (outil : GoPhish open source). 3/ Taux de clic cible < 5% après formation. 4/ Renouvellement annuel.
Responsable	DSI + RH
Ressources	Formation : plateforme Cybermalveillance.gouv.fr (gratuit) + GoPhish (open source). 1 journée DSI pour setup.
Coût estimé	0 € à 500 € selon prestataire retenu
Échéance	31 octobre 2026
Indicateur de suivi	% employés formés (cible 100%) + taux de clic simulation phishing (cible < 5%)
Criticité brute	R10 : [ELEVE] 8/16
Criticité résiduelle cible	R10 : [OK] 4/16

Champ	Détail
Preuve de clôture	Émargements de formation + rapport simulation phishing

MESURE M09 — Segmentation réseau WiFi (VLAN invité)

Risque adressé : R09 (Criticité brute 6/16 -> résiduelle 2/16)

Contrôle ISO : A.8.20 — Sécurité des réseaux

Champ	Détail
Description	1/ Créer un VLAN dédié WiFi invité isolé du réseau interne. 2/ Le réseau invité doit uniquement accéder à Internet (pas aux imprimantes, NAS, postes internes). 3/ Configurer le routeur/switch pour appliquer l'ACL.
Responsable	Thomas Rivet (DSI)
Ressources	Interne : 4h DSI. Matériel compatible VLAN déjà en place (Ubiquiti).
Coût estimé	0 € (matériel existant)
Échéance	30 septembre 2026
Indicateur de suivi	Test d'isolation réseau réussi (ping réseau interne depuis WiFi invité = échec)
Criticité brute	R09 : [MODERE] 6/16
Criticité résiduelle cible	R09 : [OK] 2/16
Preuve de clôture	Schéma réseau mis à jour + rapport test isolation

MESURE M10 — Audit plugins WordPress et politique de mise à jour

Risque adressé : R06 (contribution), R15 (Criticité 6/16 -> 4/16)

Contrôle ISO : A.8.8 — Gestion des vulnérabilités

Champ	Détail
Description	1/ Inventorier les 47 plugins WooCommerce installés. 2/ Supprimer les plugins non maintenus depuis > 12 mois. 3/ Documenter la politique : mise à jour sous 72h pour CVE critique (CVSS ≥ 9), 7 jours pour CVE élevé (CVSS ≥ 7). 4/ Automatiser les mises à jour mineures.
Responsable	Thomas Rivet (DSI)
Ressources	Interne : 1 journée DSI. WPScan (déjà déployé — poc/wpscan).
Coût estimé	0 €
Échéance	31 août 2026
Indicateur de suivi	0 plugin avec CVE > 30 jours non patché — rapport WPScan mensuel

Champ	Détail
Criticité brute	R15 : [MODERE] 6/16
Criticité résiduelle cible	R15 : [OK] 4/16
Preuve de clôture	Inventaire plugins signé DSI + politique patch documentée

MESURE M11 — Pen test annuel WooCommerce

Risque adressé : R02 (criticité résiduelle), R06

Contrôle ISO : A.8.8 — Gestion des vulnérabilités / Tests d'intrusion

Champ	Détail
Description	1/ Commander un test d'intrusion applicatif sur WooCommerce (périmètre : authentification, paiement, injection, accès données). 2/ Prestataire externe certifié OSCP/CEH. 3/ Rapport de pentest + plan de remédiation. 4/ Retest après correction.
Responsable	DSI + Direction (validation budget)
Ressources	Prestataire externe : 2-3 jours/homme.
Coût estimé	3 000 € – 5 000 € (marché PME, prestataire français)
Échéance	31 décembre 2026
Indicateur de suivi	Rapport pentest reçu + 0 vulnérabilité critique non remédiée à J+30
Criticité brute	R02 : [ELEVE] 12/16
Criticité résiduelle cible	R02 : [ELEVE] 8/16 (impact structurel RGPD)
Preuve de clôture	Rapport pentest signé + attestation retest prestataire

MESURE M12 — Formalisation PRA/PCA

Risque adressé : R01, R08 (Criticité 6/16 -> 4/16)

Contrôle ISO : A.5.29, A.5.30 — Continuité d'activité

Champ	Détail
Description	1/ Documenter le Plan de Reprise d'Activité (PRA) : RTO = 4h, RPO = 24h. 2/ Décrire les procédures de bascule pour chaque système critique (WooCommerce, Odoo, Email). 3/ Désigner un responsable de crise et un suppléant. 4/ Tester le PRA annuellement.
Responsable	DSI + DG
Ressources	Interne : 2 jours DSI
Coût estimé	0 €
Échéance	31 décembre 2026
Indicateur de suivi	PRA documenté et validé DG + 1 test annuel réalisé

Champ	Détail
Criticité brute	R08 : [MODERE] 6/16
Criticité résiduelle cible	R08 : [OK] 4/16
Preuve de clôture	Document PRA signé DG + rapport test annuel

Planning Gantt — 12 mois (Juin 2026 – Juin 2027)

Légende : || = Période active | Revue SMSI = point Direction semestriel

Budget consolidé

Coûts directs du plan de traitement

Mesure	Description	Coût unique	Coût récurrent/an
M01	MFA Google Workspace	0 €	0 €
M02	Migration S3 eu-west-3	0 €	~600 €
M03	S3 Object Lock	0 €	0 €
M04	Offboarding formel	0 €	0 €
M05	WAF Cloudflare (mode block)	0 €	0 €
M06	EDR Wazuh (VPS manager)	0 €	~240 €
M07	Test restauration PRA	5 €	20 €
M08	Formation sécurité	0 – 500 €	0 – 500 €
M09	VLAN WiFi	0 €	0 €

Mesure	Description	Coût unique	Coût récurrent/an
M10	Audit plugins WP	0 €	0 €
M11	Pen test WooCommerce	3 000 – 5 000 €	3 000 – 5 000 €
M12	PRA/PCA formel	0 €	0 €
TOTAL		3 005 – 5 505 €	3 860 – 6 360 €

Coût interne (jours DSI)

Phase	Jours estimés	Coût interne (TJM 350€)
T3 2026 — Mesures urgentes	8 jours	2 800 €
T4 2026 — Mesures structurelles	6 jours	2 100 €
T1/T2 2027 — Audit + revue	4 jours	1 400 €
Total charge interne	18 jours	6 300 €

Budget total SMSI année 1 : 9 000 € – 12 000 € Pour un CA de 3,2M€, cela représente **0,28% à 0,38% du CA**. Référence marché : une PME ISO 27001 dépense en moyenne 0,5% à 1% du CA en sécurité. TechShop est **sous la moyenne** — argument pour obtenir le budget.

Tableau de suivi — Risques avant/après traitement

ID	Risque	Criticité brute	Mesures	Criticité résiduelle	Δ	Statut
R01	Ransomware OVH	[ELEVE] 12	M03, M06, M07	[MODERE] 6	-6	En cours
R02	Fuite données clients	[ELEVE] 12	M05, M11	[ELEVE] 8	-4	Accepté direction
R03	Compromission GW Admin	[ELEVE] 12	M01	[OK] 3	-9	En cours
R04	Stripe indisponible	[MODERE] 8	Contractuel	[OK] 4	-4	Surveillé
R05	Accès ex-employé Odoo	[ELEVE] 9	M04	[OK] 3	-6	En cours
R06	Injection SQL WooCommerce	[ELEVE] 9	M05, M10	[MODERE] 6	-3	En cours
R07	Non-conformité S3/RGPD	[ELEVE] 12	M02	[OK] 2	-10	En cours
R08	Panne serveurs OVH	[MODERE] 6	M07, M12	[OK] 4	-2	Planifié
R09	Intrusion WiFi	[MODERE] 6	M09	[OK] 2	-4	Planifié

ID	Risque	Criticité brute	Mesures	Criticité résiduelle	Δ	Statut
R10	Malware phishing	[ELEVE] 8	M08	[OK] 4	-4	Planifié
R11	Backup corrompu	[ELEVE] 8	M03	[OK] 3	-5	En cours
R12	Accès données RH	[MODERE] 6	M04	[OK] 3	-3	Planifié
R13	VPN mal configuré	[MODERE] 6	Audit config	[OK] 3	-3	Planifié
R14	Bypass WAF	[MODERE] 6	M05	[OK] 3	-3	En cours
R15	Défacement WordPress	[MODERE] 6	M10	[OK] 4	-2	En cours

Résultat attendu après PTR complet :

- Risques critiques (>12) : 0 -> 0
- Risques élevés (9-12) : 6 -> **1** (R02 résiduel accepté)
- Risques modérés (5-8) : 7 -> **2** (R01, R06)
- Risques faibles (1-4) : 2 -> **12**

Décision de la direction — Risque résiduel accepté

Risque R02 — Fuite de données clients (criticité résiduelle 8/16)

La direction de TechShop SAS, représentée par Marie Laurent (DG), reconnaît que le risque de fuite de données clients ne peut être ramené à un niveau faible sans cesser l'activité e-commerce. Les mesures M05 (WAF) et M11 (pen test) réduisent significativement ce risque. Le risque résiduel de 8/16 est **formellement accepté** dans le cadre du présent SMSI. Cette acceptation sera réévaluée lors de la revue annuelle du SMSI (Juin 2027) ou en cas d'incident de sécurité touchant les données clients. **Signé** : Marie Laurent, Directrice Générale — Juin 2026

Document produit dans le cadre du SMSI TechShop SAS — Projet portfolio GRC Automation

Prochaine révision : Décembre 2026 (point d'étape semestriel)